Session 21

Implementing SSL Enhancements

For Aptech Center Use Only

Objectives

- Describe how to implement cryptography
- Explain the environment variables of SSL
- Explain how to log the server requests
- Describe how to use the parser extension of SSL modules
- Describe how to enforce core authorization
- Explain the SSL directives

For Aptech Center Use Only

© Aptech Limited

Implementing Cryptography – mos_ssl

- Depends on OpenSSL that supports SSL and Transport Layer Security (TLS) protocols for strong cryptography.

- OpenSSL is an open source cryptography library that provides a complete toolkit for SSL and TLS protocols.



- Basic Configuration of SSL:

```
Listen 443
<VirtualHost *:443>
    ServerName www.apptech.com
    SSLEngine on
    SSLCertificateFile
"/path/to/www.apptech.com.cert"
    SSLCertificateKeyFile "/path/to/www.
apptech.com.key"
</VirtualHost>
```

For Aptech Center Use Only

© Aptech Limited

Environment Variables - mod_ssl 1-2

HTTPS	• Indicates the use of HyperText Transfer Protocol Secure (HTTPS)
SSL_SESSION_ID	• Specifies session-ID of the SSL protocol in hexadecimal encoded form
SSL_PROTOCOL	• Specifies version of the SSL protocol. The value can be SSLv3, TLSv1.2, TLSv1.1, or TLSv1
SSL_SECURE_RENEG	• Generates the true value if the secure renegotiation is supported otherwise the false value is generated
SSL_SESSION_RESUMED	• Specifies the SSL session is resumed. An SSL session can process several requests if the KeepAlive directive is in use
SSL_COMPRESS_METHOD	• Indicates the SSL compression method is negotiated

For Aptech Center Use Only

© Aptech Limited

Environment Variables - mod_ssl 2-2

SSL_VERSION_INTERFACE	• Specifies version of the mod_ssl module
SSL_VERSION_LIBRARY	• Specifies version of the OpenSSL program being used
SSL_SRP_USER	• Specifies username of the Secure Remote Password (SRP) protocol
SSL_SRP_USERINFO	• Specifies the user information of SRP
SSL_TLS_SNI	• Specifies the content of the Server Name Indication (SNI) TLS extension

For Aptech Center Use Only

© Aptech Limited

Environment Variables Related to Cipher

SSL_CIPHER

- Specifies name of the cipher specification

SSL_CIPHER_EXPORT

- Generates the true value if the SSL cipher is an export cipher

SSL_CIPHER_USEKEYSIZE

- Specifies the number of cipher bits are being currently used

SSL_CIPHER_ALGKEYSIZE

- Specifies the number of cipher bits are likely being used

For Aptech Center Use Only

Environment Variables Related to SSL Client 1-3

SSL_CLIENT_M_SERIAL	• Specifies the serial number of a client certificate
SSL_CLIENT_M_VERSION	• Specifies the version of a client certificate
SSL_CLIENT_S_DN	• Specifies the subject distinguished name of a client certificate
SSL_CLIENT_S_DN_x509	• Specifies the component of the subject distinguished name of a client certificate
SSL_CLIENT_SAN_Email_n	• Specifies the extension entries for SubjectAltName (SAN) of type 'rfc822Name' of a client certificate
SSL_CLIENT_SAN_DNS_n	• Specifies the extension entries for SAN of type 'dNSName' of a client certificate

For Aptech Center Use Only

© Aptech Limited

Environment Variables Related to SSL Client 2-3

SSL_CLIENT_SAN_OTHER_msUPN_n	• Specifies the extension entries for SAN of type 'otherName' and Microsoft User Principal Name (msUPN) form of a client certificate
SSL_CLIENT_I_DN	• Specifies the issuer distinguished name of a client certificate
SSL_CLIENT_I_DN_x509	• Specifies the component of the issuer distinguished name of a client certificate
SSL_CLIENT_V_START	• Specifies the start time for the validity of a client certificate
SSL_CLIENT_V_END	• Specifies the end time for the validity of a client certificate
SSL_CLIENT_V_REMAIN	• Specifies the remaining number of days before the expiration of a client certificate

For Aptech Centre Use Only

© Aptech Limited

Environment Variables Related to SSL Client 3-3

SSL_CLIENT_A_SIG	• Specifies an algorithm for the signature of a client certificate
SSL_CLIENT_A_KEY	• Specifies an algorithm for the public key of a client certificate
SSL_CLIENT_CERT	• Specifies a Privacy Enhanced Mail (PEM)-encoded client certificate
SSL_CLIENT_CERT_CHAIN_n	• Specifies a PEM-encoded certificates in series of client certificates
SSL_CLIENT_CERT_RFC4523_CEA	• Specifies the component of the issuer distinguished name of a client certificate
SSL_CLIENT_VERIFY	• Specifies one of the values: NONE, SUCCESS, GENEROUS, or FAILED: reason

For Aptech Center Use Only

© Aptech Limited

Environment Variables of SSL Server 1-3

SSL_SERVER_M_VERSION
- Specifies the version of a server certificate

SSL_SERVER_M_SERIAL
- Specifies the serial number of a server certificate

SSL_SERVER_S_DN
- Specifies the subject distinguished name of a server certificate

SSL_SERVER_SAN_Email_n
- Specifies the extension entries for SAN of type 'rfc822Name' of a server certificate

SSL_SERVER_SAN_DNS_n
- Specifies the extension entries for SAN of type 'dNSName' of a server certificate

SSL_SERVER_SAN_OTHER_dnsSRV_n
- Specifies the extension entries for SAN of type 'otherName' and Service (SRV) Name form of a server certificate

Aptech Content Only

© Aptech Limited

Environment Variables of SSL Server

SSL_SERVER_S_DN_x509

- Specifies the component of the subject distinguished name of a server certificate

SSL_SERVER_I_DN

- Specifies the issuer distinguished name of a server certificate

For Aptech Center Use Only

Environment Variables of SSL Server

SSL_SERVER_I_DN

- Specifies the issuer distinguished name of a server certificate

SSL_SERVER_I_DN_x509

- Specifies the component of the issuer distinguished name of a server certificate

SSL_SERVER_V_START

- Specifies the start time for the validity of a server certificate

SSL_SERVER_V_END

- Specifies the end time for the validity of a server certificate

SSL_SERVER_A_SIG

- Specifies an algorithm for the signature of a server certificate

SSL_SERVER_A_KEY

- Specifies an algorithm for the public key of a server certificate

SSL_SERVER_CERT

- Specifies a PEM-encoded server certificate

For Aptech Center Use Only

© Aptech Limited

Logging of the Server Requests - mod_log_config

- Used for logging/storing the client requests.

- Directives of the `mod_log_config` module:
  - **TransferLog**: Creates a log file.
  - **LogFormat**: Specifies a custom format to use in a log file.
  - **CustomLog**: Specifies a log file and its format.

  - Example of the CustomLog directive:

```
CustomLog "logs/ssl_request_log" "%t %h
%{SSL_PROTOCOL}x %{SSL_CIPHER}x \"%r\" %b"
```

For Aptech Center Use Only

© Aptech Limited

Cryptography Format Functions 1-2

%...{version}c

- Specifies the SSL protocol version

%...{cipher}c

- Specifies the SSL cipher

%...{subjectdn}

- Specifies the subject distinguished name of a client certificate

%...{issuerdn}

- Specifies the issuer distinguished name of a client certificate

For Aptech Center Use Only

© Aptech Limited

Cryptography Format Functions 2-2

%...{errcode}c

- Specifies the verification error code of a client certificate in number form

%...{errstr}c

- Specifies the verification error description of a client certificate

For Aptech Center Use Only

© Aptech Limited

Describing the Parser Extension of the SSL Module

- `ap_expr` is the expression parser of the Apache Web Server that configures all directives of the different modules of the Web Server.
- Syntax to use the environment variables in expressions:

```
%{env_varname}
```

- Example to use the environment variables through `mod_headers`:

```
Header Set-Cookie apptechcookie "expr=-z
%{req:Cookie}"

Header append Cache-Control s-maxage=700
"expr=%{REQUEST_STATUS} == 200"
```

For Aptech Center Use Only

© Aptech Limited

Enforcing Core Authorization

- Provides support of authentication providers in `mod_ssl` using the `Require` directive of `mod_authz_core`.
- Grants access only if the connection is encrypted with SSL.
- Code to encrypt a connection with SSL:

```
Require ssl
```

- Example:

```
Require ssl-verify-client
Require valid-user
```

For Aptech Center Use Only

Introducing Online Certificate Status Protocol (OCSP) and Stapling

- OCSP is a method that provides the status of a server certificate, whether it has been revoked or not.
- OCSP stapling maintains the OCSP responses of the certificates and sends the OCSP responses to clients for communication with the server.
- An issuing Certificate Authority (CA) provides the address of an OCSP responder corresponding to each certificate.
- The `mod_ssl` module connects with an OCSP responder to get a signed response, which is authorized to send it forward for server-client communication.

For Aptech Center Use Only

© Aptech Limited

OCSP Directives of mod_ssl

SSLOCSPOverrideResponder

Activates or deactivates the default configured responder URI for OCSP certificate validation

```
SSLOCSPOverrideResponder on/off
```

SSLOCSPProxyURL

Specifies a proxy URL for the OCSP requests

```
SSLOCSPProxyURL url
```

SSLOCSPResponderTimeout

Specifies the timeout duration in seconds for the OCSP requests

```
SSLOCSPResponderTimeout duration
```

For Aptech Center Use Only

© Aptech Limited

OCSP Directives of mod_ssl 2-2

SSLOCSPResponseMaxAge

Specifies the maximum duration for the OCSP responders to process the OCSP requests

```
SSLOCSPResponseMaxAge duration
```

SSLOCSPResponseTimeSkew

Specifies the maximum time skew for the OCSP responder to process the OCSP requests

```
SSLOCSPResponseTimeSkew duration
```

SSLOCSPUseRequestNonce

Specifies the availability of a nonce or not for the OCSP requests to be processed by OCSP responders

```
SSLOCSPUseRequestNonce On|Off
```

For Aptech Center Use Only

© Aptech Limited

Stapling Directives of mod_ssl

SSLStaplingCache

- Specifies a type of SSL session cache that needs to be configured for the OCSP stapling.
- **Syntax**:
  `SSLStaplingCache type`

SSLStaplingErrorCacheTimeout duration

- Specifies the timeout in seconds before expiring the invalid responses in the OCSP stapling cache.
- **Syntax:**
  `SSLStaplingErrorCacheTimeout duration`

SSLStaplingStandardCacheTimeout

- Specifies the timeout in seconds before expiring the valid responses in the SSL stapling cache.
- **Syntax:**
  `SSLStaplingCacheTimeout duration`

For Aptech Center Use Only

© Aptech Limited

Stapling Directives of mod_ssl

SSLStaplingFakeTryLater

- Creates a 'tryLater' response for the failed requests.
- **Syntax:**
  `SSLStaplingFakeTryLater on|off`

SSLStaplingForceURL

- Overrides the URI of an OCSP responder with the URI provided by the AuthorityInfoAccess (AIA) extension of the certificate.
- **Syntax:**
  `SSLStaplingForceURL uri`

SSLStaplingResponderTimeout

- Specifies the timeout duration in seconds for the OCSP stapling requests if the SSLUseStapling directive is enabled.
- **Syntax:**
  `SSLStaplingResponderTimeout duration`

For Aptech Center Use Only

© Aptech Limited

Stapling Directives of mod_ssl

SSLStaplingResponseMaxAge

- Specifies the maximum duration for the OCSP responders to process the OCSP stapling requests.
- **Syntax:**
- `SSLStaplingResponseMaxAge duration`

SSLStaplingResponseTimeSkew

- Specifies the maximum time skew for the OCSP responder to process the OCSP stapling requests.
- **Syntax:**
- `SSLStaplingResponseTimeSkew duration`

SSLStaplingReturnResponderErrors

- Sends unsuccessful OCSP stapling queries to the clients.
- **Syntax:**
- `SSLStaplingReturnResponderErrors on|off`

For Aptech Center Use Only

© Aptech Limited

Summary

- Apache Web Server 2.4 supports the Secure Sockets Layer (SSL) protocol to ensure secure transactions over the Internet through cryptography.
- The mod_ssl module depends on OpenSSL that supports the SSL and TLS protocols for strong cryptography.
- You can use several environment variables related to cipher, client, and server of the mod_ssl module to provide SSL settings.
- The %{varname}x function is an eXtension format function that expands the environment variables provided in the mod_ssl module.
- The %{name}c function is a cryptography format function that is used for backward compatibility.

For Aptech Center Use Only

© Aptech Limited

Summary

- You can use the Require directive of mod_authz_core to provide support of authentication providers for enforcing core authorization in mod_ssl.
- OCSP stapling is a method that provides the status of a server certificate, whether it has been revoked or not.

For Aptech Center Use Only

© Aptech Limited